



- Lab Title: Security Principles
- Student Name: Sam Murice Edohoeket
- Instructor Name: Davies Caleb Chukwuka
- Date of Submission: 25/08/2026

Executive Summary

This report synthesizes three core cybersecurity domain assessments evaluating incident response, quantitative risk analysis, and information security governance.

- **Assignment 1 (CIA Triad Case Study Analysis):** Analyzed a critical healthcare ransomware incident resulting in data exfiltration, unauthorized record modification, and a 48-hour operational blackout. The assessment identified severe breaches across Confidentiality, Integrity, and Availability, classified the adversary as an organized financial crime syndicate, and structured a defense-in-depth remediation model combining physical, technical, and administrative controls with a hybrid Risk Mitigation/Transfer strategy.

- **Assignment 2 (Risk Assessment Exercise):** Performed a qualitative risk assessment across five critical assets within a higher-education enterprise architecture. By evaluating threat vectors, likelihood, and systemic impact, high-risk assets—including the Student Information System and Payment Gateway—were prioritized for active risk treatment strategies (Mitigation and Transfer).
- **Assignment 3 (Governance & Ethics Reflection):** Explored the governance hierarchy connecting external regulations, organizational policies, technical standards, and operational procedures. It established the distinction between distributed workplace security responsibility and non-delegable executive accountability, evaluating these structures through the foundational canons of the (ISC)² Code of Ethics.

Lab Objectives

- Deconstruct complex security incidents using the **CIA Triad** framework to map threat actor behaviors and system impacts.
- Formulate balanced control frameworks encompassing **Physical, Technical, and Administrative** safety measures.
- Execute a qualitative **Risk Assessment** ($\text{Level of Risk} = \text{Probability} + \text{Impact}$) to prioritize asset vulnerability remediation.
- Align strategic business decisions with recognized **Risk Treatment Strategies** (Accept, Avoid, Mitigate, Transfer).
- Evaluate corporate risk ownership and governance dynamics against **(ISC)² Professional Code of Ethics** guidelines.

Tools & Resources Used

- **Frameworks & Models:** CIA Triad Model, Qualitative Risk Matrix ($P \times I$), Risk Treatment Taxonomy, (ISC)² Code of Ethics Canons.
- **Regulatory & Compliance Baselines:** Health Insurance Portability and Accountability Act (HIPAA), Payment Card Industry Data Security Standard (PCI-DSS), General Data Protection Regulation (GDPR), ISO/IEC 27001.
- **Technical & Control References:** Endpoint Detection & Response (EDR), Immutable/Air-Gapped Backups, Role-Based Access Control (RBAC), Multi-Factor Authentication (MFA), Cloud-based DDoS Mitigation Systems.

Assignment 1: CIA Triad Case Study Analysis. Scenario: A hospital system experiences a ransomware attack; patient records are encrypted. Systems are unavailable for 48 hours. Some records are modified before encryption. Task: Identify how each CIA component was violated. Classify the threat actor. Suggest at least: 1 Physical control, 1 Technical control, 1 Administrative control. Recommend a risk treatment strategy and justify it.

CIA Triad Violations

- **Confidentiality:** Violated through unauthorized access and encryption of sensitive patient records (Protected Health Information). Because ransomware actors typically exfiltrate data before encryption (double extortion), unauthorized third parties gained access to private medical histories.
-
- **Integrity:** Violated directly by the unauthorized alteration of patient records before encryption occurred. Data manipulation compromises the trustworthiness of medical records, which directly risks patient safety during clinical decisions.
-
- **Availability:** Violated by the 48-hour system outage. Encrypting system files prevented healthcare providers from accessing critical operational tools and patient histories, halting hospital operations.
-

Threat Actor Classification

- **Cybercriminals (Organized Crime / Ransomware-as-a-Service Operators):** The primary motivation is financial gain via extortion. Healthcare entities are high-value targets for these groups due to the critical nature of continuous operations, which increases pressure to pay ransoms quickly.
-

Recommended Security Controls

- **Physical Control:** Implement biometric or smart-card access controls alongside visitor logging for server rooms and data centers to prevent physical tampering, rogue USB insertions, or unauthorized hardware access.
-
- **Technical Control:** Deploy immutable, air-gapped backups combined with Endpoint Detection and Response (EDR) software. Air-gapped backups ensure data can be restored without paying a ransom, while EDR isolates malicious ransomware processes in real time.
-
- **Administrative Control:** Mandatory role-based access control (RBAC) policies and quarterly staff security awareness training focused on phishing prevention, data handling, and incident reporting protocols.

Risk Treatment Strategy & Justification

Strategy: Risk Mitigation (Risk Reduction) combined with selective Risk Transfer.

- **Justification:** Healthcare environments cannot utilize *Risk Avoidance* (discontinuing digital patient records is non-viable) or *Risk Acceptance* (the operational, legal, and life-safety impacts are far too severe).
- Implementing robust technical, physical, and administrative controls reduces the **likelihood** and **impact** of ransomware attacks to an acceptable level (Mitigation). Additionally, acquiring specialized Cyber Insurance transfers the residual financial liabilities associated with legal penalties, forensic response costs, and downtime losses (Transfer).

Assignment 2: Risk Assessment Exercise. Students must: Identify 5 assets in a university system. Identify potential threats. Assign: Probability (High/Medium/Low), Impact (High/Medium/Low). Calculate Risk Level using: Level of Risk = Probability + Impact. Recommend treatment (Accept, Avoid, Mitigate, Transfer).

Asset 1: Student Information System (SIS) Database

- **Threat:** Ransomware attack leading to data encryption and unauthorized access to student records.
-
- **Probability:** Medium
-
- **Impact:** High
-
- **Risk Level:** High (Medium Probability + High Impact)
-
- **Recommended Treatment: Mitigate:** Deploy multi-factor authentication (MFA), role-based access control (RBAC), regular vulnerability patching, and offsite air-gapped backups.
-

Asset 2: Campus Wi-Fi Network Infrastructure

- **Threat:** Distributed Denial of Service (DDoS) attack causing widespread network downtime for staff and students.
-
- **Probability:** High
-
- **Impact:** Medium
-
- **Risk Level:** High (High Probability + Medium Impact)
-

- **Recommended Treatment: Mitigate:** Implement cloud-based DDoS protection services, rate limiting, and redundant network connections.

Asset 3: University Learning Management System (LMS - e.g., Canvas/Moodle)

- **Threat:** Credentials compromise via phishing, leading to grade tampering or unauthorized distribution of course materials.
-
- **Probability:** Medium
-
- **Impact:** Medium
-
- **Risk Level: Medium** (Medium Probability + Medium Impact)
-
- **Recommended Treatment: Mitigate:** Enforce strong password policies, mandatory MFA for staff and students, and automated activity logging.

Asset 4: Legacy Public Research Archives (Non-Sensitive Public Data)

- **Threat:** Server hardware failure causing permanent data loss of non-sensitive public research papers.
-
- **Probability:** Low
-
- **Impact:** Low
-
- **Risk Level: Low** (Low Probability + Low Impact)
-
- **Recommended Treatment: Accept:** Maintain standard periodic backups; residual risk cost is lower than implementing high-availability infrastructure.

Asset 5: Payment Gateway for Tuition & Fee Collections

- **Threat:** Data breach targeting payment channels resulting in financial theft and regulatory fines (PCI-DSS non-compliance).
-
- **Probability:** Low
-
- **Impact:** High
-
- **Risk Level: High** (Low Probability + High Impact)
-
- **Recommended Treatment: Transfer:** Outsource payment processing entirely to a PCI-DSS certified third-party vendor and acquire cyber liability insurance to transfer financial exposure.

Assignment 3: Governance & Ethics Reflection. Students must: Explain the relationship between: Policies Standards Procedures Regulations Then analyze this statement: “Security is everyone’s responsibility, but accountability belongs to leadership.” Finally, connect their answer to the ISC2 Code of Ethics principles: Protect society; Act honorably and legally; Provide diligent service.

The Interplay of Cybersecurity Framework Components

Cybersecurity governance relies on a structured hierarchy of documentation and regulatory controls to align organizational behavior with legal requirements and risk tolerances. To build a defense-in-depth posture, an organization must synthesize four core mechanisms: policies, standards, procedures, and regulations.

[Regulations] (External Laws & Frameworks)



[Policies] (High-Level Management Directives)



[Standards] (Mandatory Baselines & Requirements)



[Procedures] (Step-by-Step Implementation Instructions)

- **Regulations:** Mandatory requirements imposed by external governing bodies, legislative authorities, or industry groups (such as GDPR, HIPAA, PCI-DSS, or ISO/IEC 27001 compliance directives). Regulations define the legal boundaries, data protection mandates, and financial or operational penalties an organization faces if it fails to protect sensitive data or maintain system availability. They serve as the outermost constraint driving internal security architecture.
- **Policies:** High-level, executive-mandated statements of intent that establish an organization’s security philosophy, roles, and risk posture. Written broadly to ensure longevity, policies reflect leadership's strategic commitment to security. They define *what* needs to be protected and *why*, establishing the authoritative mandate for all downstream controls.
- **Standards:** Mandatory baseline measurements, configurations, or technical choices derived directly from policy directives. Standards define *what specific parameters* must be met to satisfy policy objectives (e.g., mandating AES-256 encryption for data at rest or requiring WPA3 for wireless networking). They ensure technical uniformity across an enterprise.

- **Procedures:** Detailed, step-by-step instructions that dictate *how* personnel perform specific tasks to achieve compliance with established standards and policies. Procedures are tactical and operational, such as the exact sequence an IT administrator follows to provision a user account or perform a daily backup verification.

Analysis: “Security is Everyone’s Responsibility, but Accountability Belongs to Leadership”

This principle encapsulates the operational vs. ultimate ownership paradox in enterprise cybersecurity risk management.

- **Responsibility across the Workforce:** Security responsibility is distributed across every employee, contractor, and third-party vendor. A single user clicking a malicious link in a spear-phishing email or reusing credentials can bypass millions of dollars in technical security controls. Every staff member has a duty to maintain security awareness, adhere to operational procedures, report anomalies, and practice sound security hygiene within their daily workflows.
- **Accountability at the Executive Level:** Responsibility refers to executing assigned tasks, whereas accountability denotes ultimate ownership of outcomes. Executive leadership (the Board of Directors, CEO, CISO, and executive officers) holds the non-delegable duty to establish, resource, and oversee the cybersecurity program.
-

Leadership alone controls resource allocation, risk appetite determination, organizational culture, and policy enforcement. When a catastrophic breach occurs, individual employees may face disciplinary action for failing their operational responsibilities, but leadership remains legally, fiscally, and ethically accountable to shareholders, regulatory bodies, patients, customers, and the public. A failure in security is fundamentally a failure in leadership oversight, risk management strategy, or resource allocation.

Alignment with the (ISC)² Code of Ethics Canons

The foundational tenets of professional cybersecurity practice are codified in the (ISC)² Code of Ethics, which provides a moral compass for balancing operational demands, leadership duties, and legal obligations.

(ISC) ² Ethics Canon	Practical Application in Governance & Leadership

1. Protect society, the common good, necessary public trust and confidence, and the infrastructure.

- **Governance Alignment:** Regulations and high-level policies exist primarily to safeguard critical infrastructure and public safety.

- **Leadership Duty:** Leadership must not treat compliance as a mere checkbox exercise. Failing to fund adequate defenses directly endangers patient health data, personal identities, and economic stability.

- **Ethical Mandate:** Practitioners and executives must prioritize public safety and systemic trust above short-term corporate cost-saving.

2. Act honorably, honestly, justly, responsibly, and legally.

- **Governance Alignment:** Fulfilling legal requirements (regulations) and maintaining honest corporate communications.

- **Leadership Duty:** Executives must transparently disclose security postures, risks, and breaches rather than concealing vulnerabilities to protect stock value or reputation.

- **Ethical Mandate:** Practitioners must follow established standards and procedures rigorously, refusing to bypass security controls for personal convenience or operational shortcuts.

3. Provide diligent and competent service to principals.	• Governance Alignment: Translating policies into clear standards and operational procedures that enable business goals securely. • Leadership Duty: Leadership fulfills diligence by adequately resourcing security programs, empowering C-suite security officers, and fostering a culture where every employee understands their role. • Ethical Mandate: Cybersecurity professionals must maintain technical competence, perform accurate risk assessments, and execute security duties thoroughly to safeguard the organization's assets.
--	---

Recommendations

1. **Deploy Layered Technical Controls:** Enforce mandatory MFA, RBAC, and EDR agents across all enterprise endpoints. Maintain offline, immutable data backups to guarantee resilience against ransomware attacks without financial capitulation.
2. **Standardize Risk Governance:** Maintain an active Enterprise Risk Register based on standardized \$Probability \times Impact\$ formulas. Review high-value data repositories (e.g., payment gateways, database systems) quarterly to apply timely risk transfer (cyber insurance/outsourcing) or mitigation controls.
3. **Institutionalize Ethical Leadership:** Formalize policy-to-procedure mappings to ensure staff compliance with legal mandates while retaining ultimate risk accountability at the executive level. Execute mandatory security awareness training to reinforce shared responsibility across the organizational culture.

References

- ISO/IEC. (2022). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (ISO/IEC Standard No. 27001:2022). International Organization for Standardization.
- (ISC)². (2021). *(ISC)² Code of Ethics*. International Information System Security Certification Consortium.
- National Institute of Standards and Technology. (2012). *Guide for Conducting Risk Assessments* (NIST Special Publication 800-30, Revision 1). U.S. Department of Commerce.
- National Institute of Standards and Technology. (2018). *Framework for Improving Critical Infrastructure Cybersecurity* (Version 1.1). U.S. Department of Commerce.